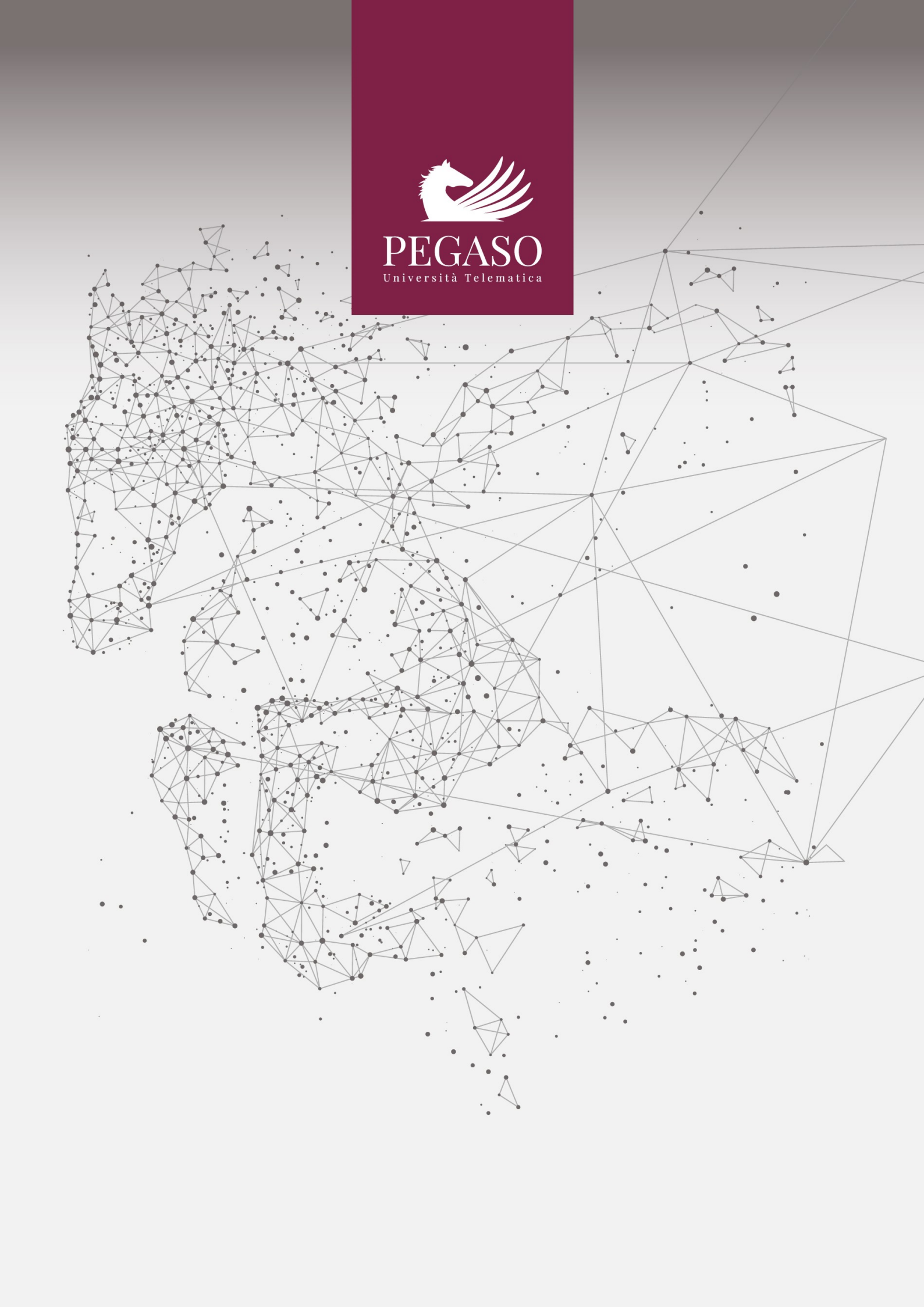

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Indice

1 FIREWALL: I PRINCIPI BASE 3
2 FIREWALL: LE CARATTERISTICHE 4
3 TIPI DI FIREWALL 5
4 SICUREZZA MULTILIVELLO 7
BIBLIOGRAFIA 10

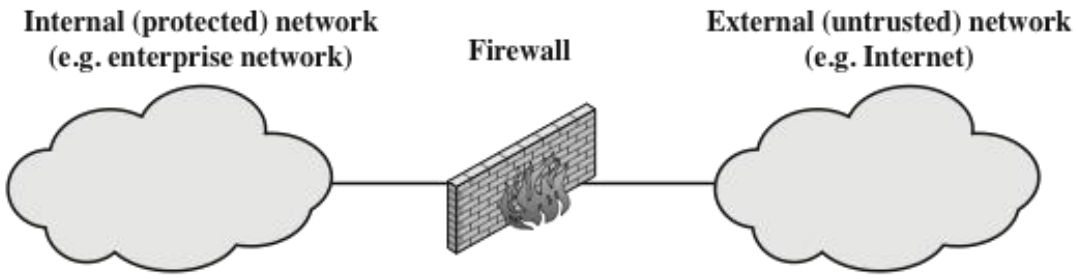
Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

1 Firewall: i principi base

L'accesso a Internet fornisce indiscutibili benefici per le aziende, le organizzazioni e anche per i privati; dall'altro lato però ciò consente anche al mondo esterno di poter raggiungere sia i computer personali sia i sistemi presenti su una rete interna (rete aziendale) che si trovano esposti su Internet. Su una singola workstation è possibile installare funzionalità di sicurezza adeguate ma ciò non è molto conveniente quando si ha che fare con una rete interna composta da molte macchine con caratteristiche disparate (e.g. sistemi operativi diversi, versioni differenti)

Una soluzione alternativa o, perlomeno complementare, alla sicurezza basata sui servizi presenti su ciascun host è costituita dal **firewall**.

Il firewall si frappone tra la rete interna e Internet, stabilendo un collegamento controllato ed erigendo appunto una barriera verso l'esterno (vedi figura sottostante).



Gli scopi del firewall sono fondamentalmente:

- proteggere la rete interna dagli attacchi provenienti da Internet
- fornire un unico punto di accesso in cui imporre la sicurezza e la registrazione degli auditing

Il firewall può essere tuttavia un singolo sistema informatico oppure due o più sistemi che cooperano tra di loro per svolgere tale funzione.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

2 Firewall: le caratteristiche

Tutto il traffico dall'interno verso l'esterno e viceversa deve passare attraverso il firewall (si bloccano tutti gli accessi fisici alla rete locale); solo il traffico autorizzato, secondo la politica di sicurezza locale definita, potrà passare (esistono differenti tipologie di firewall e diverse politiche di sicurezza). Il firewall stesso deve essere immune agli attacchi (uso di sistemi sicuri).

Uno degli aspetti cruciali nella progettazione dei sistemi firewall è senza dubbio costituito dalla definizione di adeguate politiche di accesso. La politica definisce il tipo di traffico autorizzato a passare attraverso il firewall, e tramite questa si può effettuare un filtraggio su:

- il range di indirizzi IP e la direzione del flusso
- il tipo di applicazione
- l'identità degli utenti
- l'attività di rete (evitare lo spam o tentativi di scanning)
- il tipo di contenuti

Un firewall è in grado di offrire varie funzionalità come:

- definire un punto unico di accesso tale da mantenere fuori dalla rete interna gli utenti non autorizzati o processi/servizi pericolosi
- costituire un punto di osservazione (auditing) di eventi relativi alla sicurezza
- essere utilizzato per implementare delle reti private virtuali (VPN)
- essere anche utilizzato per gestire altri servizi Internet anche non specifici per la sicurezza

Di contro un firewall non può offrire certe funzionalità quali:

- non può proteggere da attacchi o da traffico su connessioni che lo oltrepassano
- non può proteggere da minacce provenienti dall'interno
  - un dipendente insoddisfatto o che coopera inconsapevolmente con un hacker
  - dispositivi (laptop, chiavi USB) che infettate da virus sono utilizzate nella rete interna

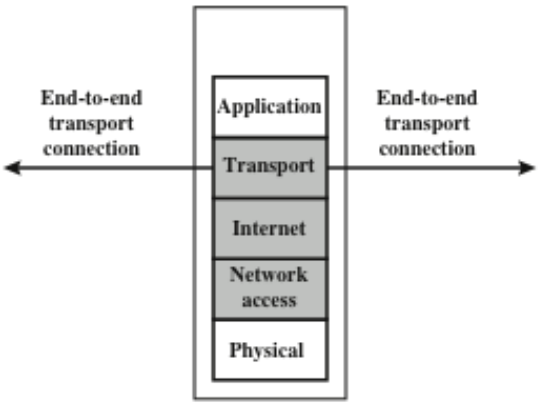
connessioni wireless effettuate da sistemi della rete interna

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

3 Tipi di firewall

Esistono ovviamente varie tipologie di firewall, analizziamo intanto in dettaglio il funzionamento del **firewall a filtraggio di pacchetti IP**.



In questo tipo di firewall il filtraggio avviene sui pacchetti di rete in base a differenti regole:

- indirizzo IP sorgente/destinazione
- numero di porta a livello di trasporto che definisce una specifica applicazione (per esempio la porta 25 assegnata per la posta elettronica)
- campo del protocollo IP che definisce il protocollo di trasporto

Vediamo come tali regole possono essere implementate nel caso per esempio del traffico SMTP di posta elettronica (vedi tabella di seguito).

PEGASO Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Regola	Direzione	Indirizzo sorgente	Indirizzo destinaz.	Protocollo	Porta destinaz.	Azione
A	IN	ESTERNO	INTERNO	TCP	25	OK
B	OUT	INTERNO	ESTERNO	TCP	>1023	OK
C	OUT	INTERNO	ESTERNO	TCP	25	OK
D	IN	ESTERNO	INTERNO	TCP	>1023	OK
E	ENTRAMBI	QUALSIASI	QUALSIASI	QUALSIASI	QUALSIASI	KO

La politica, in questa circostanza, è basata su cinque regole. Le regole A e C garantiscono l'entrata e l'uscita del traffico di posta mentre le regole B e D permettono le rispettive risposte alla posta rispettivamente ricevuta e inviata. Invece la regola E blocca tutto il resto del traffico.

Il firewall a filtraggio di pacchetti IP presenta alcuni vantaggi: prima di tutto la sua implementazione è piuttosto semplice ed offre sia trasparenza verso gli utenti che elevata velocità. Dall'altro lato, presenta però degli svantaggi in quanto non esamina i dati ai livelli superiori e quindi non può proteggere da attacchi che sfruttano specifiche vulnerabilità delle applicazioni che appunto si trovano a livello applicazione (più in alto nella gerarchia a livelli); inoltre non supporta meccanismi avanzati di autenticazione degli utenti e si manifesta vulnerabile ad attacchi di tipo *spoofing*.

Esistono comunque anche altre tipologie di firewall che a seconda delle specifiche esigenze applicative e di sicurezza possono essere implementati:

- *A ispezione di stati*: il firewall non controlla solo i pacchetti ma certi protocolli e le relative connessioni.
- *Gateway a livello applicazione (proxy)*: se il proxy non implementa una specifica applicazione, tale servizio non viene supportato
- *Host bastione*: sistema identificato come punto critico per la sicurezza di rete che serve da gateway.

Host-based (personal) firewall: modulo software per proteggere un singolo host (personal computer).

PEGASO Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

4 Sicurezza multilivello

Con il termine di *sicurezza multilivello* si intende una politica di gestione della sicurezza in cui le informazioni sono accessibili sulla base di diversi livelli gerarchici. Ciò per esempio accade nel caso di dati segreti relativi ad ambienti militari oppure in contesti aziendali. Quello che accade di solito è che le informazioni possono essere categorizzate in varie tipologie quali: *non classificate*, *confidenziali*, *segrete*, *top-secret*, ecc. L'accesso a tali informazioni è regolato a seconda del livello di privilegio del personale. Inoltre vige la regola base che un soggetto ad alto livello non deve fornire informazioni ad un soggetto di livello inferiore a meno che non ci sia una specifica autorizzazione.

La sicurezza multilivello nell'accesso alle informazioni, soprattutto per evitare la fuoriuscita di dati sensibili, può essere realizzata tramite l'implementazione di due semplici proprietà:

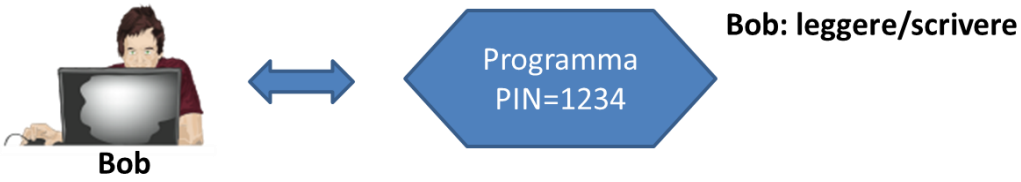
- **No read up**: un soggetto può solo leggere un oggetto/informazione con un livello di sicurezza uguale o inferiore (rispetto al livello a cui è autorizzato)
- **No write down**: un soggetto può solo scrivere in un oggetto/informazione con un livello di sicurezza uguale o superiore (rispetto al livello a cui è autorizzato)

Vediamo adesso un esempio di come queste due proprietà possono proteggere un sistema di gestione dati nel caso di un attacco con un Cavallo di Troia ideato per entrare in possesso di credenziali segrete (e.g. un PIN segreto) a cui l'utente Bob che possiede un account di livello 1 (*riservato*) può accedere.

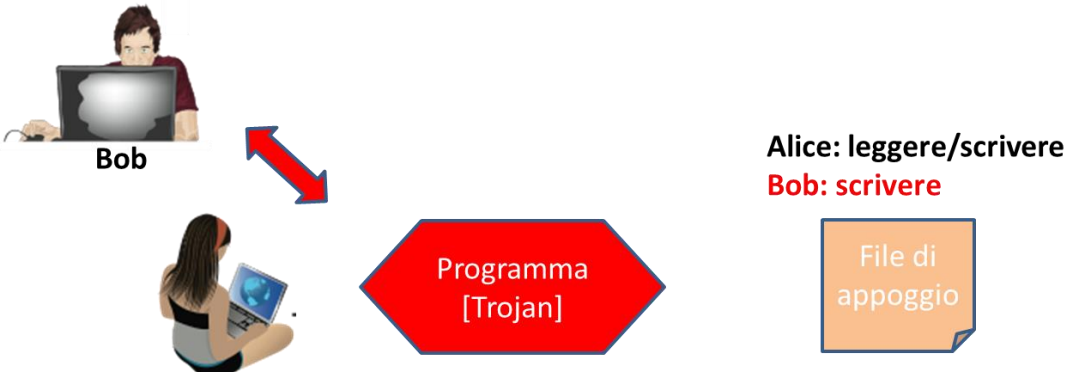
Supponiamo che Bob possa eseguire/scrivere/leggere un programma che contiene le informazioni segrete (PIN=1234) a cui un altro utente Alice, facente parte della stessa azienda ma con un livello inferiore di privilegi (livello 2 *pubblico*), è interessato ad accedere.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).



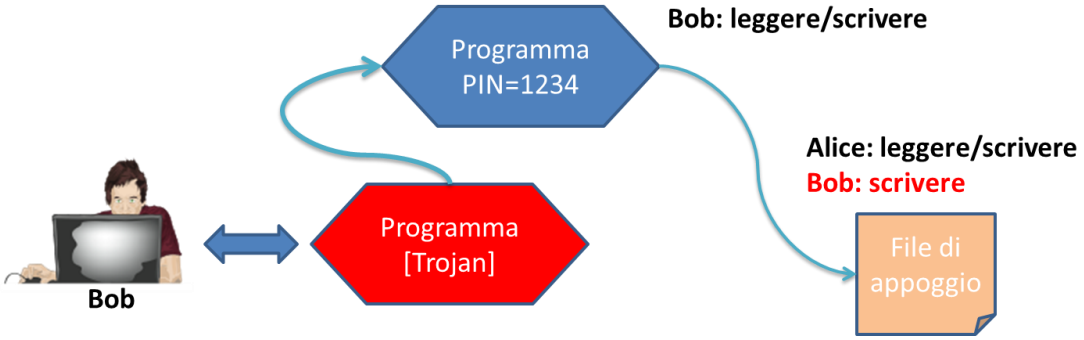
Allora Alice crea un programma contenente un trojan che compie l'azione di leggere il PIN e copiarlo in un file di appoggio. Alice lo invia a Bob e lo convince ad eseguirlo



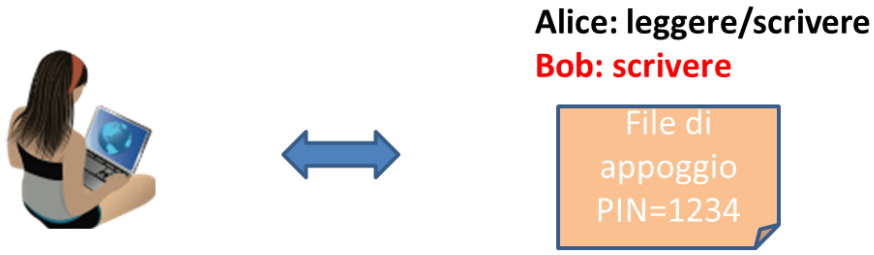
Bob esegue il programma ed avendo un profilo di livello 1, anche il trojan riceve quel livello e può effettuare il suo attacco leggendo il PIN e copiandolo nel file per cui Alice ha concesso a Bob il permesso di scrittura.

PEGASO
Università Telematica

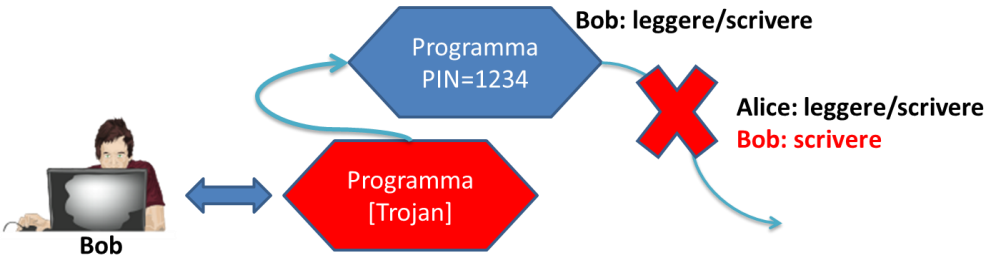
Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).



Alice ha così trasferito un'informazione dal livello 1 *riservato* in un file, da lei creato, di livello 2 *pubblico* ovvero di livello inferiore, a cui lei può accedere in lettura.



Nel caso invece di implementazione della proprietà «no write down», il cosiddetto *monitor di riferimento* che controlla gli accessi degli utenti agli oggetti secondo, appunto, certe regole, avrebbe impedito l'operazione di scrittura su un file di livello inferiore (da livello riservato a livello pubblico), pur avendo Bob il permesso di scrittura.



Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Bibliografia

- Libro di riferimento "Crittografia e Sicurezza delle Reti" 2 ed., William Stallings, Ed. McGraw-Hill: *Capitoli 20.*
- "Cryptography and Network Security", 7/ed, William Stallings, Pearson, *Capitolo 23*.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).